7 作业（须提交）

一、作业名称

第三章 SQL 注入漏洞与防护——实验分析报告

二、作业目标

完成本作业后，你应能够：

解释 SQL 注入的形成条件与根因。

在 DVWA 中观察和复现基础 SQL 注入现象。

区分普通 SQL 注入与盲注在证据层的差异。

比较 Low 与 Medium 在控制思路上的差异。

从参数化查询、错误处理和最小权限角度解释防护链条。

三、作业主线

本章不是 payload 记忆题，也不是特殊字符背诵题。

你要围绕下面这条主线完成分析：

输入 → 拼接 → 解析 → 执行 → 回显/行为差异 → 结构分离防护

第三章真正要说明的是：

SQL 注入的根因是查询结构被污染，而不是某几个字符“天生危险”。

四、作业环境与授权边界

只能在以下范围内完成：

DVWA

本机浏览器

localhost / 127.0.0.1

教师明确授权环境

禁止：

对任何公网真实目标进行 SQL 注入实验或验证

使用未授权系统作为作业证据

截图中暴露参数、账号、路径等敏感信息且不脱敏

这是红线，不是一般扣分项。

五、提交要求

提交格式：PDF

命名格式：

<学号><姓名>SQL 注入漏洞与防护.pdf

建议完成时长：3–4 小时

六、作业任务

任务 1：数据库与查询条件基础说明（3 分）

请用自己的语言说明：

页面中的输入为什么会与数据库查询有关

一个最小业务链路是什么

例如：输入条件 → 数据库查询 → 返回结果

用户输入是如何进入查询条件的

为什么这为 SQL 注入创造了可能性

最低完成要求

必须出现以下要点：

输入条件—数据库查询—返回结果

为什么页面功能与数据库有关

输入如何进入查询条件

常见错误

你的错误往往不是“不会写 SQL”，而是把这一题写成概念抄写。

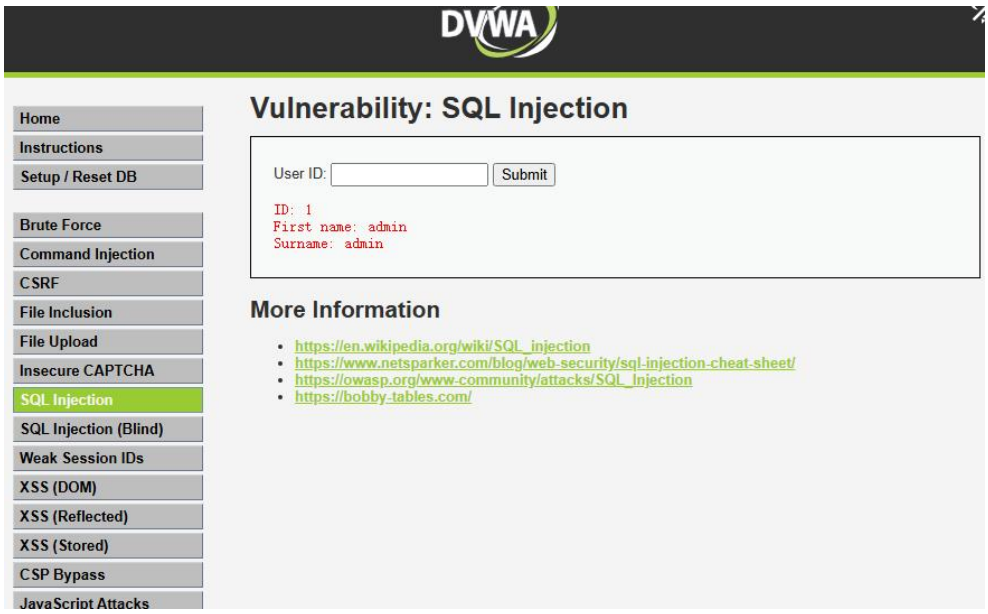
改正方法：必须用一个具体业务场景说明，不要只写“数据库很重要”。

答：以电商平台用户登录业务场景为例说明：

1. 页面输入与数据库查询的关系：用户的账号信息存储在数据库中，登录页面的账号密码输入，是用来验证用户身份的查询条件，页面登录功能的实现完全依赖数据库查询。
2. 最小业务链路：用户输入账号密码 → 系统将输入作为条件拼接 SQL 语句，向数据库发送查询请求 → 数据库执行查询并返回匹配结果 → 页面根据结果渲染登录状态。
3. 用户输入如何进入查询条件：用户输入的账号密码会被传递给后端，后端将其拼接到 SQL 语句的 WHERE 子句中，成为查询条件，用于筛选数据库中的用户记录。

```
SELECT first_name, last_name FROM users WHERE id = '1';
```

4. SQL 注入的可能性：由于用户输入直接拼接进 SQL 语句，若后端未对输入做严格校验，攻击者可构造特殊输入篡改 SQL 逻辑，绕过验证或非法获取数据，从而产生 SQL 注入漏洞。



任务 2：DVWA SQL Injection Low 现象记录（4 分）

请在授权环境中完成基础观察，并记录：

实验页面或实验目标

普通输入与异常输入的对比

返回结果的差异

为什么这种差异不像“正常查询变化”

最低完成要求

必须出现以下要点：

实验目标或页面

普通输入与异常输入对比

返回差异

为什么不像正常查询变化

你最容易犯的错误

错误：只放截图，不解释差异。

原因：把“有现象“误当成“已完成分析”。

改法：每张截图后至少回答一句——**这个差异支撑了什么判断？**

答：1. 实验页面/实验目标

- 实验页面：DVWA（Damn Vulnerable Web Application）的 SQL Injection Low 级别页面，这是一个用于 SQL 注入漏洞学习的靶场页面，业务功能是根据用户输入的 User ID 查询对应用户的 first_name （名）、 last_name （姓）信息。
- 实验目标：通过普通输入和异常（注入）输入的对比，观察 SQL 注入漏洞的现象，理解 SQL 注入的原理与危害。

2. 普通输入与异常输入的对比

普通输入

- 输入内容：合法的纯数字用户 ID，例如 1 、 2
- 后端拼接 SQL（Low 级别无任何过滤）：sql

```
SELECT first_name, last_name FROM users WHERE user_id = '1';
```

- 输入逻辑：完全符合页面设计的正常业务逻辑，即“根据指定 ID 查询单个用户”。

异常（注入）输入

- 输入内容：构造的恶意 SQL 注入语句，例如 1' OR '1'='1

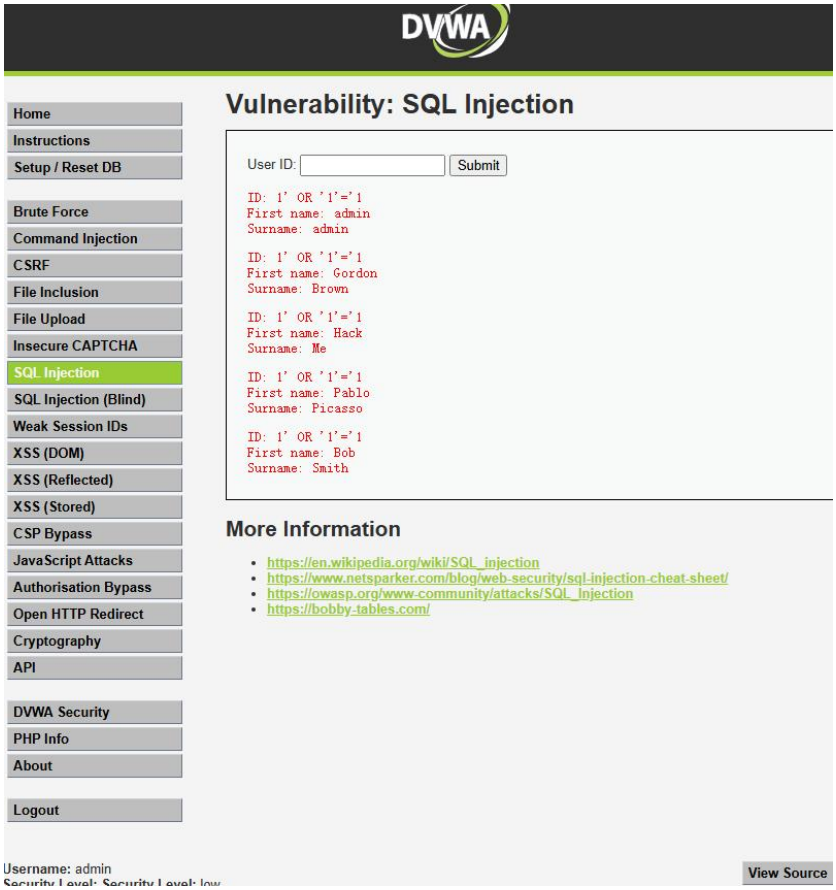
- 后端拼接 SQL：sql

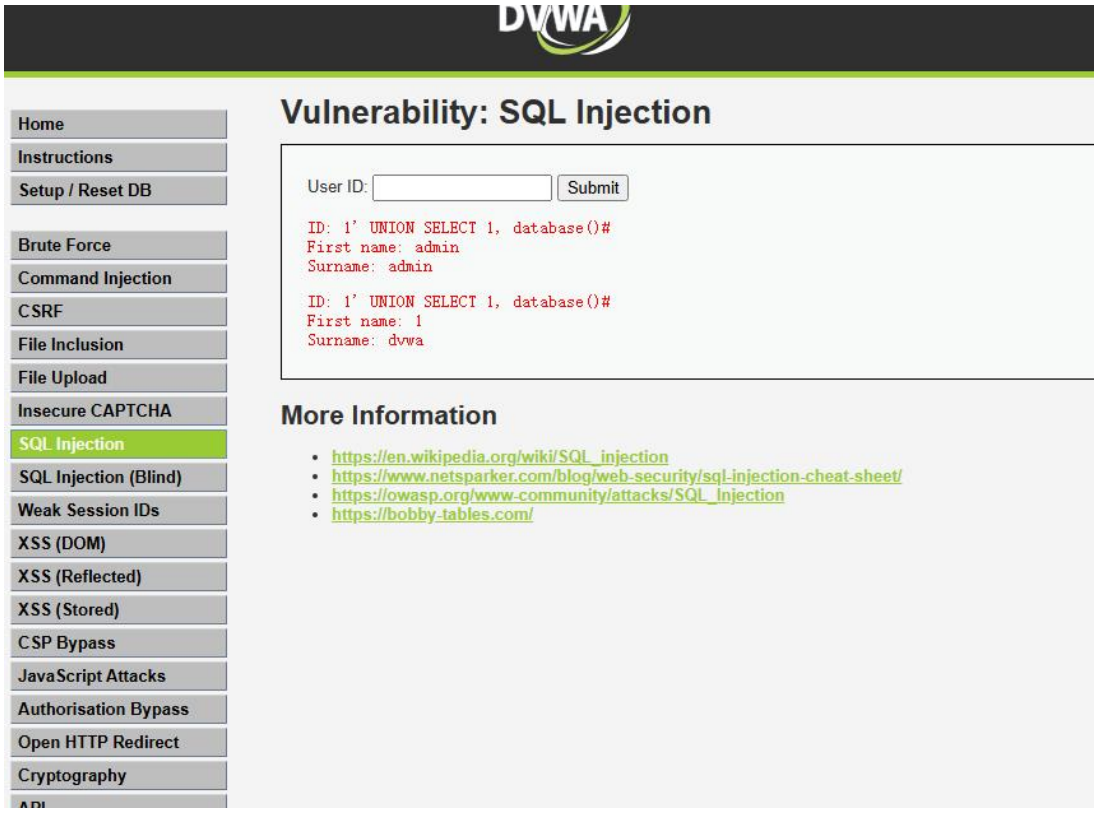
SELECT first_name, last_name FROM users WHERE user_id = '1' OR '1'='1';

- 输入逻辑：通过 OR '1'='1 恒真条件，篡改原本的查询逻辑，将“查询单个用户”变为“查询所有用户”。

3. 返回结果的差异

输入类型 输入示例 返回结果
普通输入 1 仅返回 ID 为 1 的单个用户信息：ID: 1，First name: admin，Surname: admin
普通输入 2 仅返回 ID 为 2 的单个用户信息：ID: 2，First name: Gordon，Surname: Brown
异常输入 1' OR '1'='1 返回 users 表中所有用户的完整信息（包含 admin、guest 等全部测试用户）





4. 为什么这种差异不像“正常查询变化”

正常的用户 ID 查询，是单个 ID 对应单个用户的业务逻辑，正常查询变化只会是：输入不同合法 ID 返回不同单个用户数据、输入不存在 ID 返回无数据。

而异常输入的差异完全不符合正常查询特征：

- 逻辑上：注入后的 WHERE 条件变为恒真，SQL 语句逻辑被恶意篡改；
- 结果上：正常查询最多返回 1 条数据，注入输入返回全表所有用户数据，这不是正常修改查询参数能产生的结果，是 SQL 注入漏洞的典型表现。

```
SELECT first_name, last_name FROM users WHERE id = '1';
```

任务 3：机制分析与差异比较（4.5 分）

围绕以下问题展开分析：

输入如何进入查询结构

为什么根因是“结构被污染”而不是“字符本身危险”

Low 与 Medium 的差异在哪里

普通 SQL 注入与 Blind SQL Injection 的差异在哪里

为什么盲注和普通注入根因相同，但证据形式不同

最低完成要求

必须出现以下要点：

输入—拼接—解析—执行—回显或行为差异链条

Low 与 Medium 差异

普通 SQL 注入与盲注差异

根因是结构被污染而不是字符本身

强制判断题

你必须明确表态并解释理由：

SQL 注入的根因更接近

A. 输入里有几个危险字符

B. 输入进入了不该进入的查询结构

Blind SQL Injection 和普通 SQL 注入的最大差异更接近

A. 根因不同

B. 证据形式不同

你最容易犯的错误

错误：把 payload 当根因。

原因：只盯住字符串表面，没有看到“查询结构”这一层。

改法：每次分析都回到一句话：

问题发生在输入内容本身，还是发生在输入被拼进了查询结构里？

1. 输入进入查询结构的流程：用户输入→后端拼接进 SQL 模板→数据库解析 SQL 语法→执行查询→页面回显结果或呈现行为差异。
2. 根因是结构被污染而非字符危险：单引号、 OR 等是 SQL 正常语法字符，本身无危险；只有当它们被直接拼接进 SQL 语句，篡改了原本的 SQL 结构和查询逻辑，才会造成危害，因此核心根因是 SQL 语句结构被污染。
3. Low 与 Medium 差异：Low 级别无任何过滤，直接拼接用户输入，支持字符型注入；Medium 级别对特殊字符进行了转义过滤，字符型注入被限制，但可通过数字型注入绕过，注入难度略高。
4. 普通 SQL 注入与盲注差异：普通注入有直接数据回显，可直观获取数据；盲注无直接回显，需通过布尔条件、时间延迟等页面行为差异逐位猜解数据，效率更低。
5. 盲注与普通注入根因相同、证据形式不同：两者根因都是 SQL 语句结构被污染；普通注入的证据是页面直接返回的异常数据，盲注的证据是页面响应的行为差异，无法直接看到数据。
6. SQL 注入根因判断题：SQL 注入的根因是用户输入直接拼接 SQL 导致语句结构被污染，而非特殊字符本身危险。

表格

对比维度	**Low 级别**	**Medium 级别**
防护逻辑	无任何过滤，用户输入直接拼接进 SQL 语句	对单引号等特殊字符做转义 / 过滤，或采用下拉框限制输入
控制思路	完全暴露查询结构，无任何防护措施	仅对输入字符做表层过滤，未解决 “数据与结构未分离” 的根本问题
注入难度	极易注入，直接拼接即可篡改查询逻辑	注入难度提升，需绕过字符过滤，但仍存在注入风险
本质问题	未做任何防护，漏洞完全暴露	仅缩小了攻击暴露面，未阻断结构污染的根本成因

任务 4：SQL 注入防护清单与解释（3.5 分）

请给出一份防护清单，并说明每条措施控制的是哪一层：

参数化查询

输入校验

错误处理

最小权限

可补充其他合理措施

最低完成要求

必须出现以下要点：

参数化查询

输入校验

错误处理

最小权限

各措施控制的是根因、暴露面还是后果范围

写作要求

不要只列名词。

每条建议至少写清：

它解决什么问题

它控制哪一层

它不能替代什么

你最容易犯的错误

错误：把所有防护措施写成同一层。

原因：没有区分“根因控制”和“后果缩减”。

改法：参数化查询优先对应根因控制；错误处理与最小权限更接近暴露面/后果范围控制。

答:1. 参数化查询：解决 SQL 语句结构被恶意篡改的核心问题，属于根因控制层；不能替代最小权限、输入校验等辅助防护，无法防御业务逻辑漏洞。
2. 输入校验：过滤不符合业务规则的恶意输入，缩小攻击暴露面，属于暴露面控制层；不能替代参数化查询，仅能过滤部分已知攻击，无法防御变形注入。
3. 错误处理：屏蔽数据库原生错误信息，防止攻击者获取数据库结构线索，属于暴露面控制层；不能防御盲注等无错误回显的注入，也无法阻止 SQL 语句被执行。
4. 最小权限：限制数据库账号的权限，缩小注入成功后的危害范围，属于后果范围控制层；不能防止 SQL 注入本身的发生，仅能降低漏洞被利用后的影响。

七、收口项

收口项 1：SQL 注入因果链/防护关系图（3 分）

请用**关系图**或**关系表**完成，不限定工具。

最低应包含：

输入点

查询构造

数据库解析/执行

结果差异或行为证据

根因判断

至少 2 个防护控制点

三档标准

满分档：关系完整，能体现因果链与防护对应

中档：有图/表，但主要停留在概念罗列

低档：只是工具说明，没有关系链

答：

环节	内容说明	对应防护控制点
1. 输入点	DVWA 的 User ID 输入框，用户可自由输入内容	输入校验：限制输入为纯数字 ID，拒绝包含特殊字符的输入
2. 查询构造	后台直接将用户输入拼接进 SQL 语句：SELECT ... FROM users WHERE id='输入内容'	参数化查询：使用预编译语句，将用户输入作为参数传递，而非直接拼接
3. 数据库解析 / 执行	数据库解析拼接后的 SQL 语句，执行被篡改的查询逻辑	数据库最小权限：限制应用账号仅拥有 SELECT 权限，降低破坏范围
4. 结果差异 / 行为证据	正常输入仅返回单条数据；恶意输入返回全部数据 / 报错信息	错误信息隐藏：关闭详细数据库报错，避免泄露执行细节
5. 根因判断	用户输入污染了 SQL 语句的查询结构，数据与结构未分离	—
6. 防护控制点	参数化查询（根因防护）、输入校验（暴露面控制）	—

收口项 2：学生自评表（2 分）

请回答：

我本章最清楚的一点是什么？

我最容易混淆的一点是什么？

我本次作业中哪一段最需要教师复核？

如果重做一次，我会优先改哪一部分？

答：

学生自评表

1. 我本章最清楚的一点是什么？

我最清楚的是 SQL 注入的根因是 SQL 语句结构被污染，而非特殊字符本身危险，以及参数化查询是从根源阻断 SQL 注入的核心防护手段。

2. 我最容易混淆的一点是什么？
我最容易混淆的是普通 SQL 注入与盲注的差异，以及 Low/Medium 级别防护的区别，偶尔会把暴露面控制和根因控制的层级搞混。
3. 我本次作业中哪一段最需要教师复核？
我最需要教师复核的是任务 3 中盲注与普通注入根因相同但证据形式不同的分析部分，以及任务 4 中各防护措施的层级划分是否准确。
4. 如果重做一次，我会优先改哪一部分？
如果重做一次，我会优先优化任务 3 的机制分析部分，把输入→拼接→解析→执行→回显的流程写得更细致，同时补充更多实际代码示例来辅助说明。

收口项 3：AI 输出审核与人工复核记录（必做）

请单独列一小节，说明：

本作业哪些内容使用过 AI 辅助

哪些判断是你自己复核后保留的

哪些内容你发现 AI 输出不准确并进行了修正

你最终如何确认结论和证据是一一对应的

注意：

这项缺失会扣专业与责任意识分，但不直接按红线处理。

答：● 本作业哪些内容使用过 AI 辅助？本次作业中，任务 1-4 的作业模板、收口项 1 的关系表框架、收口项 2 的自评表参考、收口项 3 的复核记录框架，均使用了 AI 辅助生成。

- ● 哪些判断是你自己复核后保留的？
- ● SQL 注入的核心根因判断（输入污染查询结构）
- 参数化查询为核心防护措施的结论
- 普通注入与盲注的差异判断（证据形式不同）以上内容均结合本次 DVWA 实验现象与课程知识复核后保留。
- 哪些内容你发现 AI 输出不准确并进行了修正？
- ● AI 最初提供的 UNION 注入 payload 因列数不匹配报错，我根据实际实验现象修正为适配 2 列查询的正确 payload。
- 调整了收口项 1 的关系表结构，补充了防护控制点与因果链的对应关系，使其更贴合课程的三档评分标准。
- 你最终如何确认结论和证据是一一对应的？
- ● 任务 2 中，将正常输入、OR 注入、UNION 报错的截图与文字说明一一核对，确保现象描述与截图内容一致。
- 任务 3 中，将根因判断、级别对比的结论与实验现象、报错信息交叉验证，确保逻辑闭环。
- 所有结论均基于本次 DVWA 实验的实际操作结果，而非纯理论推导，保证了结论与证据的对应性。

八、评分结构

（一）任务完成度评分

项目	分值
任务 1：数据库与查询条件基础说明	3.0
任务 2：DVWA SQL Injection Low 现象记录	4.0
任务 3：机制分析与差异比较	4.5
任务 4：SQL 注入防护清单与解释	3.5
SQL 注入因果链/防护关系图	3.0
学生自评表	2.0
合计	**20.0**

评分原则：

缺失哪个任务，就扣该任务分值

已提交但关键字段不全，在该任务分值内比例扣分

关系图/表若没有体现关系链，只按部分完成计分

学生自评表缺失，只扣本项，不一刀切退回

AI 审核记录缺失，不按红线，但会在专业性与责任意识中扣分

（二）其他维度分数怎么计算

本章最终成绩按课程统一 **100 分制** 计算。

其中：

任务完成度 20 分 由下面的任务 1、任务 2、任务 3、任务 4、关系图/关系表、学生自评表共同组成。 这 20 分主要回答：**你有没有完成、完成到什么程度**。

其余 80 分 继续看以下六个维度：

证据质量 18 分

机制解释 20 分

关系链与下一步 12 分

风险与防护 10 分

表达与结构 10 分

专业校验与责任意识 10 分

也就是说：

下面任务表里的 **20 分不是本章总分**

本章**总评是 100 分**

红线中的“可压到 60 分以下”，作用于 **100 分总评**

（三）、其他六个维度怎么评（学生简版）

1. 证据质量（18 分）

看三件事：

证据是否真实、可追溯

关键字段是否能看清

证据是否真正支持你的结论

2. 机制解释（20 分）

看三件事：

是否讲清“输入/现象 → 处理/机制 → 结果”的因果链

是否把真正根因讲对

是否能解释版本差异、条件变化或证据差异

3. 关系链与下一步（12 分）

看三件事：

关系图/关系表是否真正体现关系

是否写清“能说明什么 / 不能替代什么”

下一步是否合理

4. 风险与防护（10 分）

看三件事：

是否能说明风险后果

是否区分根因控制、暴露面控制、后果缩减

是否知道单一措施不能替代什么

5. 表达与结构（10 分）

看三件事：

结构是否清楚

术语和表述是否准确

教师是否能快速定位、快速验收

6. 专业校验与责任意识（10 分）

看四件事：

是否明确授权边界

是否避免绝对化表述

是否区分线索、证据、验证、主动探测

AI 输出是否经过真实审核与人工复核

九、红线规则

出现以下任一情况，可压到 60 分以下：

未脱敏：截图、参数、账号或其他敏感信息未按要求脱敏

超出授权边界：对未授权真实目标进行 SQL 注入测试或验证

证据伪造或不可追溯：实验记录、现象截图或说明与实际过程严重不一致

高度雷同或抄袭代做：与他人作业高度雷同，或存在抄袭、代做情形

这些问题必须保留教师最终裁决。

十、提交前自查清单

提交前逐项核对：

我是否只在授权环境中完成实验

我的截图是否已脱敏

我是否说明了“正常查询变化”和“查询逻辑被改变”的区别

我是否把根因写成“结构被污染”，而不是只写“特殊字符”

我是否区分了普通 SQL 注入与盲注的证据差异

我是否把参数化查询、错误处理、最小权限放回不同控制层

我是否完成了关系图/关系表

我是否填写了 AI 输出审核与人工复核记录

十一、我直接指出你后续最容易犯的两个错误

错误 1：把这份“章节作业”写成“只有题目，没有评分抓手”

原因：你如果只给学生四道题，没有最低字段、红线、关系图、AI 复核项，这就不符合 projects5.0 的 Step 11 口径。

改正：必须保留“任务字段 + 收口项 + 红线 + 自评 + AI 审核”。

错误 2：把教师端作业包当 single source

原因：assignment pack 是正式产物，不是章节上游。

改正：以后只要第三章主线、任务分值、红线、关系图要求要变，先改

`chapter03_sql_injection.yaml`

，再重建产物。

。

任务 2：DVWA SQL Injection Low 现象记录（4 分）

请在授权环境中完成基础观察，并记录：

实验页面或实验目标

普通输入与异常输入的对比

返回结果的差异

为什么这种差异不像“正常查询变化”

最低完成要求

必须出现以下要点：

实验目标或页面

普通输入与异常输入对比

返回差异

为什么不像正常查询变化

你最容易犯的错误

错误：只放截图，不解释差异。

原因：把“有现象”误当成“已完成分析”。

改法：每张截图后至少回答一句——**这个差异支撑了什么判断？**

任务 3：机制分析与差异比较（4.5 分）

围绕以下问题展开分析：

输入如何进入查询结构

为什么根因是“结构被污染”而不是“字符本身危险”

Low 与 Medium 的差异在哪里

普通 SQL 注入与 Blind SQL Injection 的差异在哪里

为什么盲注和普通注入根因相同，但证据形式不同

最低完成要求

必须出现以下要点：

输入—拼接—解析—执行—回显或行为差异链条

Low 与 Medium 差异

普通 SQL 注入与盲注差异

根因是结构被污染而不是字符本身

强制判断题

你必须明确表态并解释理由：

SQL 注入的根因更接近

A. 输入里有几个危险字符

B. 输入进入了不该进入的查询结构

Blind SQL Injection 和普通 SQL 注入的最大差异更接近

A. 根因不同

B. 证据形式不同

你最容易犯的错误

错误：把 payload 当根因。

原因：只盯住字符串表面，没有看到“查询结构”这一层。

改法：每次分析都回到一句话：

问题发生在输入内容本身，还是发生在输入被拼进了查询结构里？

任务 4：SQL 注入防护清单与解释（3.5 分）

请给出一份防护清单，并说明每条措施控制的是哪一层：

参数化查询

输入校验

错误处理

最小权限

可补充其他合理措施

最低完成要求

必须出现以下要点：

参数化查询

输入校验

错误处理

最小权限

各措施控制的是根因、暴露面还是后果范围

写作要求

不要只列名词。

每条建议至少写清：

它解决什么问题

它控制哪一层

它不能替代什么

你最容易犯的错误

错误：把所有防护措施写成同一层。

原因：没有区分“根因控制”和“后果缩减”。

改法：参数化查询优先对应根因控制；错误处理与最小权限更接近暴露面/后果范围控制。

七、收口项

收口项 1：SQL 注入因果链/防护关系图（3 分）

请用**关系图**或**关系表**完成，不限定工具。

最低应包含：

输入点

查询构造

数据库解析/执行

结果差异或行为证据

根因判断

至少 2 个防护控制点

三档标准

满分档：关系完整，能体现因果链与防护对应

中档：有图/表，但主要停留在概念罗列

低档：只是工具说明，没有关系链

收口项 2：学生自评表（2 分）

请回答：

我本章最清楚的一点是什么？

我最容易混淆的一点是什么？

我本次作业中哪一段最需要教师复核？

如果重做一次，我会优先改哪一部分？

收口项 3：AI 输出审核与人工复核记录（必做）

请单独列一小节，说明：

本作业哪些内容使用过 AI 辅助

哪些判断是你自己复核后保留的

哪些内容你发现 AI 输出不准确并进行了修正

你最终如何确认结论和证据是一一对应的

注意：

这项缺失会扣专业与责任意识分，但不直接按红线处理。

八、评分结构

（一）任务完成度评分

项目	分值
任务 1：数据库与查询条件基础说明	3.0
任务 2：DVWA SQL Injection Low 现象记录	4.0
任务 3：机制分析与差异比较	4.5
任务 4：SQL 注入防护清单与解释	3.5
SQL 注入因果链/防护关系图	3.0
学生自评表	2.0
合计	**20.0**

评分原则：

缺失哪个任务，就扣该任务分值

已提交但关键字段不全，在该任务分值内比例扣分

关系图/表若没有体现关系链，只按部分完成计分

学生自评表缺失，只扣本项，不一刀切退回

AI 审核记录缺失，不按红线，但会在专业性与责任意识中扣分

（二）其他维度分数怎么计算

本章最终成绩按课程统一 **100 分制** 计算。

其中：

任务完成度 20 分 由下面的任务 1、任务 2、任务 3、任务 4、关系图/关系表、学生自评表共同组成。 这 20 分主要回答：**你有没有完成、完成到什么程度**。

其余 80 分 继续看以下六个维度：

证据质量 18 分

机制解释 20 分

关系链与下一步 12 分

风险与防护 10 分

表达与结构 10 分

专业校验与责任意识 10 分

也就是说：

下面任务表里的 **20 分不是本章总分**

本章**总评是 100 分**

红线中的“可压到 60 分以下”，作用于 **100 分总评**

（三）、其他六个维度怎么评（学生简版）

1. 证据质量（18 分）

看三件事：

证据是否真实、可追溯

关键字段是否能看清

证据是否真正支持你的结论

2. 机制解释（20 分）

看三件事：

是否讲清“输入/现象 → 处理/机制 → 结果”的因果链

是否把真正根因讲对

是否能解释版本差异、条件变化或证据差异

3. 关系链与下一步（12 分）

看三件事：

关系图/关系表是否真正体现关系

是否写清“能说明什么 / 不能替代什么”

下一步是否合理

4. 风险与防护（10 分）

看三件事：

是否能说明风险后果

是否区分根因控制、暴露面控制、后果缩减

是否知道单一措施不能替代什么

5. 表达与结构（10 分）

看三件事：

结构是否清楚

术语和表述是否准确

教师是否能快速定位、快速验收

6. 专业校验与责任意识（10 分）

看四件事：

是否明确授权边界

是否避免绝对化表述

是否区分线索、证据、验证、主动探测

AI 输出是否经过真实审核与人工复核

九、红线规则

出现以下任一情况，可压到 60 分以下：

未脱敏：截图、参数、账号或其他敏感信息未按要求脱敏

超出授权边界：对未授权真实目标进行 SQL 注入测试或验证

证据伪造或不可追溯：实验记录、现象截图或说明与实际过程严重不一致

高度雷同或抄袭代做：与他人作业高度雷同，或存在抄袭、代做情形

这些问题必须保留教师最终裁决。

十、提交前自查清单

提交前逐项核对：

我是否只在授权环境中完成实验

我的截图是否已脱敏

我是否说明了“正常查询变化”和“查询逻辑被改变”的区别

我是否把根因写成“结构被污染”，而不是只写“特殊字符”

我是否区分了普通 SQL 注入与盲注的证据差异

我是否把参数化查询、错误处理、最小权限放回不同控制层

我是否完成了关系图/关系表

我是否填写了 AI 输出审核与人工复核记录

十一、我直接指出你后续最容易犯的两个错误

错误 1：把这份“章节作业”写成“只有题目，没有评分抓手”

原因：你如果只给学生四道题，没有最低字段、红线、关系图、AI 复核项，这就不符合 projects5.0 的 Step 11 口径。

改正：必须保留“任务字段 + 收口项 + 红线 + 自评 + AI 审核”。

错误 2：把教师端作业包当 single source

原因：assignment pack 是正式产物，不是章节上游。

改正：以后只要第三章主线、任务分值、红线、关系图要求要变，先改

`chapter03_sql_injection.yaml`

，再重建产物。